PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation du poste de travail multi-environnements

03-320 ANSSI - Sécurisation du poste de travail multi-environnements — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le cloisonnement entre systèmes d'exploitation complets concerne les éditeurs et ne vise pas l'isolation d'applicatifs.
2. L'intégrité, l'authenticité et le non-retour en arrière de la chaîne de démarrage sont assurés par UEFI Secure Boot et Measured Boot sur TPM.
3. La journalisation des transferts via des diodes entre domaines utilisateurs doit être systématique avec ses métadonnées complètes pour éviter tout canal de communication non surveillé.

Principes généraux du poste multi-environnements

Notion	À retenir
Cloisonnement physique	Recommandé si sensibilité, menaces ou entités diffèrent, mais conduit à **un poste par environnement** ; le multi-environnements répond aux contraintes de **coût, mobilité, ergonomie, empreinte**.
Périmètre	Destiné aux **éditeurs** ; cloisonnement entre **OS complets**, pas l'isolation d'applicatifs. Niveaux **NP** ou **DR** (II 901 : NP/NP, NP/DR, DR/DR) ; pas Secret/Très Secret ; poste **mono-utilisateur**.
Choix des VM	Utiliser des **machines virtuelles** pour cloisonner les domaines utilisateurs, plus fort que les **sandbox** (primitives du noyau).

Fonctions de sécurité du socle

Notion	À retenir
Chaîne de démarrage	Assurer l'**intégrité**, l'**authenticité** et le **non-retour en arrière** via **UEFI Secure Boot** et **Measured Boot** sur **TPM**. Firmware non modifiable par l'utilisateur.
Chiffrement et mémoire	Protéger les données (confidentialité, intégrité, authenticité). Utiliser un **TPM** pour les secrets. Chiffrement **DRAM** contre attaques **coldboot**. Accès mémoire restreint.
Durcissement du socle	Appliquer **défense en profondeur**, **séparation des privilèges**, **moindre privilège** et **minimisation de la surface d'attaque**. Contrôle par **moniteur de référence** (**SELinux** ou **AppArmor**).

Périphériques, réseau et temps

Notion	À retenir
Périphériques	Instance **VMM dédiée** par domaine utilisateur ; **émulation** préférable à la délégation (**PCI passthrough**) ; périphériques externes rattachés au **socle**.
Réseau	Configuration **hors de portée** des domaines et de l'utilisateur (sauf choix du Wi-Fi) ; flux du socle dans un **VPN non débrayable** ; communications entre domaines **interdites** ; tout flux **filtré par le socle**.
Sources de temps	Source **intègre** (ex: **NTS**) ; temps **commun** au socle et aux domaines supports pour corréler les événements.

Journalisation, mise à jour et exploitation

Notion	À retenir
La journalisation	Dédiée à un **domaine support**. Contient : dysfonctionnements, mises à jour, authentifications/déconnexions, tunnels **VPN**. Doit être protégée (**intégrité/authenticité**). Pas de clés privées. Pas d'envoi des journaux **domaine utilisateur** vers le socle.
La mise à jour	Doit être **signée** avec contrôle à l'application. Utiliser un système **atomique avec fallback** pour rester fonctionnel en cas d'échec. L'**échec** doit être journalisé.
L'exploitation par rôles	Chaque action (ex: **administrateur**, **auditeur**, **mise à jour**) a un rôle défini. Exécuté dans un **domaine support** (privilèges minimum, sans accès données utilisateurs) avec **authentification forte**.

Démarrage, affichage et échanges

Notion	À retenir
Démarrage et authentification	Mécanisme de démarrage sécurisé et **RTM** (ex: **TPM virtuel** dédié/distinct). Authentification **obligatoire** sur le socle avant l'accès aux domaines.
Affichage et options	Connaissance du domaine via une **barre de confiance**. Options (ex: **Wi-Fi**, **mot de passe**) possibles en **domaines supports dédiés** sans impacter le socle.
Communication entre domaines	Communications **proscrites**, sauf via **diodes unidirectionnelles** dédiées. Transfert de fichiers désignés, via **interface graphique cloisonnée** et **journalisés**.

Recommandations non fonctionnelles

> Socle au moins aussi sensible que le **domaine le plus sensible** ; documentation (surface d'attaque, modèle d'attaquant) et **SBOM** à jour ; **effacement sécurisé** ; délai de correctifs fixé **dès la conception**.

Pièges et confusions

- ⚠ Confondre une sensibilité identique avec un droit d'accès identique entre deux domaines utilisateurs.
- ⚠ Détourner le système de diodes pour créer un canal de communication non surveillé.
- ⚠ Oublier la journalisation systématique des métadonnées lors d'un transfert via diode.
- ⚠ Négliger l'isolation de domaines utilisateurs ayant le même niveau de sensibilité.

Sigles et définitions

Poste de travail multi-environnements	Poste destiné à faire cohabiter plusieurs environnements ne partageant pas le même niveau de sensibilité avec des garanties de sécurité proches du cloisonnement physique.
Domaine	Environnement d'exécution d'une ou plusieurs tâches sur le socle, défini par l'ensemble des ressources sur lesquelles la tâche peut agir.
TCB	Ensemble des logiciels et matériels critiques pour la sécurité du système.
Socle	Ensemble des matériels et logiciels permettant de faire fonctionner les domaines, incluant la TCB, et assurant l'isolation entre les différents domaines.
Moniteur de référence	Logiciel qui autorise ou interdit l'action d'une tâche sur une ressource, sur la base d'une politique de sécurité.
TPM	Composant sécurisé passif, matériel ou virtuel, effectuant des opérations cryptographiques selon la norme ISO/IEC 11889.
RTM	Composant de sécurité physique permettant d'établir une chaîne de confiance mesurée dès le démarrage.

Auto-test

1. Quel est l'objectif du cloisonnement entre domaines ?
2. Quelle source de temps intègre le socle peut-il utiliser ?
3. Quels niveaux d'environnement le document couvre-t-il ?
4. Par où transitent les flux originaires du socle ?
5. Que se passe-t-il si un bug survient dans la TCB ?

Réponses : **1.** Garantir qu'un domaine n'accède pas aux ressources d'un autre domaine, sauf de manière contrôlée par une politique de sécurité. · **2.** NTS. · **3.** Non Protégé (NP) et Diffusion Restreinte (DR), au sens de l'II 901. · **4.** Par un VPN chiffrant non débrayable maîtrisé par l'entité. · **5.** Cela entraîne généralement la compromission complète du système.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.